OntoCSIRT: Desenvolvimento e Aplicação de uma Ontologia OWL com Regras SWRL para Análise de Incidentes de Cibersegurança e Recuperação de Casos de Resposta

Nome do Aluno[1]

Programa de Pós-Graduação em Ciência da Computação
Instituição – Cidade – UF – Brasil

aluno@instituicao.br

Abstract. *This paper presents the development and application of OntoCSIRT, an OWL 2 DL ontology for cybersecurity incident analysis. Incidents are reified and linked to the four VERIS A4 elements, to CVE-identified vulnerabilities and CWE weaknesses, and to historical response cases. Eight SWRL rules derive risk levels, recurrently critical assets, shared actors and weaknesses, and candidate solutions; two defined classes are classified in OWL. The ontology was processed with Owlready2, Pellet, HermiT, SPARQL and SHACL. All 8 competency questions, 20 rule tests and 10 injected defects behaved as expected. In a leave-one-out evaluation over 24 synthetic cases, ontology-based similarity reached 0.69 top-1 accuracy, against 0.25 for the join used in the previous version.*

Resumo. *Este trabalho apresenta o desenvolvimento e a aplicação da OntoCSIRT, uma ontologia OWL 2 DL para análise de incidentes de cibersegurança. Os incidentes são reificados e ligados aos quatro elementos do modelo VERIS A4, a vulnerabilidades identificadas por CVE, a fraquezas CWE e a casos históricos de resposta. Oito regras SWRL derivam níveis de risco, ativos com incidentes críticos recorrentes, atores e fraquezas partilhados e soluções candidatas; duas classes definidas são classificadas em OWL. A ontologia foi processada com Owlready2, Pellet, HermiT, SPARQL e SHACL. As 8 questões de competência, os 20 testes de regras e os 10 defeitos injetados tiveram o comportamento esperado. Numa avaliação* leave-one-out *sobre 24 casos sintéticos, a similaridade baseada na ontologia obteve acurácia de 0,69 no primeiro colocado, contra 0,25 da junção usada na versão anterior.*

1. Introdução

A resposta a incidentes passou a ser tratada como parte da gestão de riscos de cibersegurança na revisão 3 da publicação SP 800-61 do NIST [Nelson et al., 2025]. Para cada incidente, uma equipe de resposta (CSIRT) precisa decidir quais ativos

foram atingidos, quais fraquezas foram exploradas, qual é a gravidade do evento e o que foi feito em situações parecidas. Essas informações estão espalhadas por vocabulários diferentes: o modelo A4 do VERIS descreve incidentes por ator, ação, ativo e atributo [VERIS Community, 2026]; o STIX 2.1 descreve objetos de inteligência de ameaças [OASIS, 2021]; e o NVD e a CWE descrevem vulnerabilidades e fraquezas [NIST, 2026, MITRE, 2026].

Uma ontologia permite reunir esses vocabulários num modelo único e explícito, sobre o qual um raciocinador verifica a consistência e deriva conhecimento implícito [W3C OWL Working Group, 2012]. Regras SWRL acrescentam inferências que a lógica de descrição sozinha não expressa, como comparações numéricas [Horrocks et al., 2004], e o Raciocínio Baseado em Casos (CBR) permite reutilizar soluções de incidentes anteriores [Aamodt and Plaza, 1994]. O OntoCSD [Wu et al., 2024] e o trabalho de Guerra et al. [Guerra et al., 2023] já combinaram ontologias e CBR no domínio de defesa e resposta a incidentes.

Problema. Dado um incidente novo, descrito pelos seus elementos VERIS e pela vulnerabilidade envolvida, como (i) classificar a sua gravidade e o seu contexto de forma verificável e (ii) recuperar, entre incidentes históricos, aqueles cuja resposta registrada é mais provável de servir?

Objetivo. Desenvolver a ontologia OntoCSIRT em OWL 2 DL com regras SWRL, processá-la com ferramentas disponíveis (Owlready2, Pellet, HermiT, rdflib e pySHACL) e aplicá-la ao problema acima. As contribuições são:

1. a ontologia, com separação entre padrões de ataque abstratos e ações concretas, atores concretos agrupados pelas categorias do VERIS e alinhamento declarado ao STIX 2.1 e ao VERIS (Seção 3.);

2. oito regras SWRL e duas classes definidas em OWL, testadas com casos positivos e negativos (Seções 3. e 5.);

3. uma função de similaridade que usa a hierarquia da ontologia para recuperar casos, comparada com quatro estratégias de base numa avaliação *leave-one-out* (Seções 4. e 5.);

4. um protocolo de avaliação reproduzível, com questões de competência, testes de regras e injeção de defeitos, e o registro dos defeitos que ele encontrou nas versões anteriores e nas ferramentas.

Para isto, o trabalho está dividido em sete seções. A Seção 2. apresenta os conceitos e os trabalhos relacionados. A Seção 3. descreve o desenvolvimento da ontologia. A Seção 4. descreve a sua aplicação ao problema. A Seção 5. apresenta os resultados. A Seção 6. compara o trabalho com os relacionados, e a Seção 7. conclui e indica trabalhos futuros.

2. Fundamentação e Trabalhos Relacionados

2.1. Vocabulários do domínio

O VERIS organiza a descrição de um incidente em quatro elementos, conhecidos como A4: o *ator* que agiu, a *ação* realizada, o *ativo* afetado e o *atributo* de segurança comprometido (confidencialidade, integridade ou disponibilidade) [VERIS Community, 2026]. Os atores são classificados em externos, internos e parceiros. O STIX 2.1 define objetos de domínio como `attack-pattern`, `threat-actor`, `vulnerability`, `infrastructure`, `course-of-action` e `incident`, e relações nomeadas entre eles [OASIS, 2021]. A CWE cataloga tipos de fraqueza de software, e o NVD publica registros de vulnerabilidades (CVE) com pontuação CVSS e fraquezas associadas [MITRE, 2026, NIST, 2026].

2.2. OWL, SWRL, SPARQL e SHACL

A OWL 2 DL é decidível e permite declarar classes, propriedades, disjunções, propriedades funcionais e classes definidas por condições necessárias e suficientes [W3C OWL Working Group, 2012]. A SWRL acrescenta regras do tipo Horn sobre os mesmos predicados, incluindo funções embutidas (*builtins*) para comparar valores [Horrocks et al., 2004]. Para manter a decidibilidade, raciocinadores como o Pellet aplicam as regras apenas a indivíduos nomeados, o que corresponde às regras *DL-safe* [Motik et al., 2005, Sirin et al., 2007]. A OWL adota a hipótese de mundo aberto e não assume nomes únicos; por isso, dois indivíduos só são considerados diferentes se isso for declarado. O SPARQL é a linguagem de consulta sobre grafos RDF [W3C SPARQL Working Group, 2013], e o SHACL valida restrições de mundo fechado, como cardinalidade mínima e vocabulários controlados, que a OWL não verifica [Knublauch and Kontokostas, 2017].

2.3. Raciocínio Baseado em Casos

No ciclo clássico do CBR, um problema novo é usado para recuperar casos semelhantes; a solução do caso recuperado é reutilizada, revista e, se for útil, retida como novo caso [Aamodt and Plaza, 1994]. A qualidade da recuperação depende da representação dos casos e da função de similaridade.

2.4. Ontologias para incidentes e trabalhos relacionados

Há ontologias para o tratamento de incidentes, como a CSIHO [Moreira, 2018], e trabalhos recentes para incidentes em sistemas de TIC e para remediação contextualizada [Tailhardat et al., 2024, Kanawati et al., 2026]. A CIRPO estende a CSIHO para modelar atividades e comunicações do processo de resposta, e foi avaliada num exercício simulado de *ransomware* [Galadima et al., 2027]. Do lado do conhecimento sobre ameaças, a UCO é uma ontologia unificada de cibersegurança [Syed et al., 2016], o SEPSES integra dados públicos de vulnerabilidades e fraquezas num grafo de conhecimento [Kiesling et al., 2019], e o D3FEND organiza contramedidas [Kaloroumakis and Smith, 2021]. Um mapeamento sistemático examinou em que medida

ontologias centrais de segurança seguem os princípios FAIR [Oliveira et al., 2021].

Dois trabalhos são os mais próximos deste. O **OntoCSD** [Wu et al., 2024] usa OWL para representar ameaças, vulnerabilidades, estados de segurança e estratégias de defesa, quatro regras SWRL executadas com o HermiT no Protégé e o myCBR para gerar esquemas de decisão; foi validado por doze especialistas (coeficiente de concordância de Kendall $W = 0{,}695$) e quatro cenários num sistema real de defesa de redes. O trabalho de **Guerra et al.** [Guerra et al., 2023] propõe um método de resolução de problemas baseado em casos, com uma ontologia de ações de resolução, compara planos de resposta como sequências ordenadas de ações e avalia uma base de 102 casos revisados por especialistas; não inclui descoberta por regras. Em paralelo, modelos de linguagem passaram a ser usados para planejar respostas, com a necessidade de reduzir alucinações [Hammar et al., 2026], e ontologias com SHACL foram usadas para validar grafos extraídos por esses modelos [Cotti et al., 2026].

3. Desenvolvimento da Ontologia

O desenvolvimento seguiu a METHONTOLOGY [Fernández-López et al., 1997], com as atividades de especificação, aquisição de conhecimento, conceitualização, integração, formalização, implementação, avaliação e documentação, repetidas em ciclos de prototipação. A versão descrita é a sétima; as anteriores e os defeitos que motivaram cada mudança estão resumidos na Seção 3.5.. A Figura 1 resume o processo e a sua aplicação.

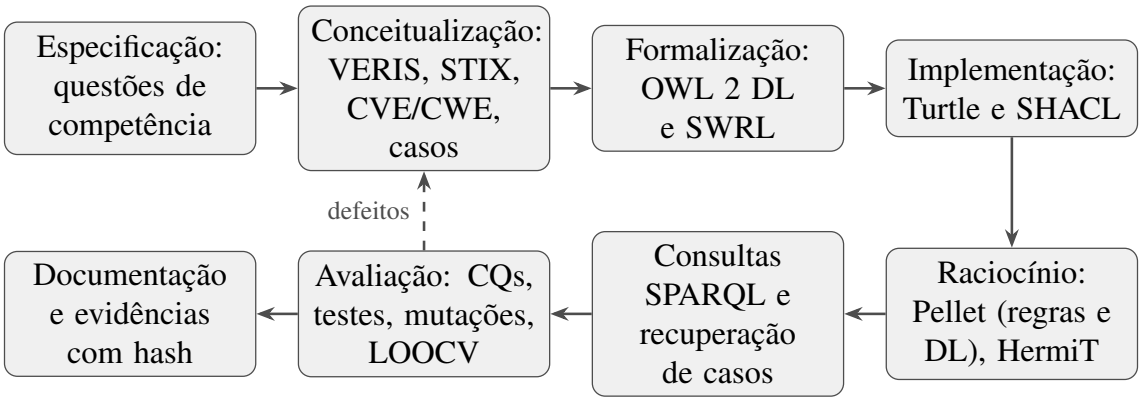


Figure 1. Processo de desenvolvimento (linha superior) e de processamento e avaliação (linha inferior). A seta tracejada indica o retorno à conceitualização quando a avaliação encontra defeitos.

3.1. Especificação

O domínio é a análise de um incidente por um CSIRT, desde o registro dos elementos do evento até a escolha de uma ação de resposta. Os usuários previstos são analistas de resposta. Os requisitos foram escritos como questões de competência [Grüninger and Fox, 1995] e cada uma foi implementada como uma consulta SPARQL com a resposta esperada definida antes da execução (Tabela 1).

Table 1. Questões de competência; a coluna da direita é o número de respostas esperadas, conferido na Seção 5..

ID	Questão	Esperado
CQ1	Quais incidentes têm risco *Critical*?	9
CQ2	Quais ativos têm incidentes críticos recorrentes?	3
CQ3	Que incidentes partilham a fraqueza do `Incident_03`?	2
CQ4	Que soluções a regra R6 propõe para o `Incident_03`?	2
CQ5	Que incidentes com risco à confidencialidade envolvem ator interno?	3
CQ6	Que incidentes envolvem fraqueza de controle de acesso?	5
CQ7	Que incidentes de injeção no servidor afetaram a confidencialidade?	4
CQ8	Que vulnerabilidades com CVE ainda não foram verificadas contra o NVD?	3

3.2. Conceitualização e integração

O incidente é a entidade central e reificada, ligada aos quatro elementos do VERIS por `hasActor`, `hasAction`, `hasAsset` e `hasAttribute`, e à vulnerabilidade envolvida por `involvesVulnerability` (Figura 2). Três decisões de modelagem orientaram a conceitualização.

Tipo e ocorrência separados. Um padrão de ataque (`AttackPattern`) é um tipo abstrato e reutilizável, como "injeção de SQL". A ação concreta de um incidente é um indivíduo de `ThreatAction`, que instancia um padrão (`instantiatesPattern`) e explora uma vulnerabilidade concreta (`exploits`). Assim, o padrão nunca fica ligado a um ativo específico.

Atores concretos e categorias do VERIS. As categorias do VERIS são classes disjuntas (`ExternalActor`, `InternalActor` e `PartnerActor`), e os atores são indivíduos concretos dessas classes. Isso permite distinguir "o mesmo ator" de "um ator da mesma categoria", distinção cuja ausência produzia correlações espúrias na versão anterior (Seção 3.5.).

Fraquezas com categoria própria. Cada CWE é um indivíduo de `Weakness` e pertence a uma de seis categorias definidas neste trabalho (injeção no servidor, cliente web, controle de acesso, autenticação, tratamento de recursos e falsificação de requisição no servidor). As categorias servem à similaridade e não reproduzem a hierarquia oficial da CWE.

A integração com os vocabulários externos é declarada por propriedades de anotação: `verisCategory` indica o elemento VERIS correspondente, e `stixType` indica o objeto STIX 2.1 mais próximo (por exemplo, `Asset` corresponde aproximadamente a `infrastructure`). Optou-se por anotações, e não por equivalências OWL, porque o STIX não é publicado como ontologia e as correspondências não são exatas. Os registros com CVE trazem a fonte do dado (`dcterms:source`) e o estado de verificação contra o NVD (`verificationNote`).

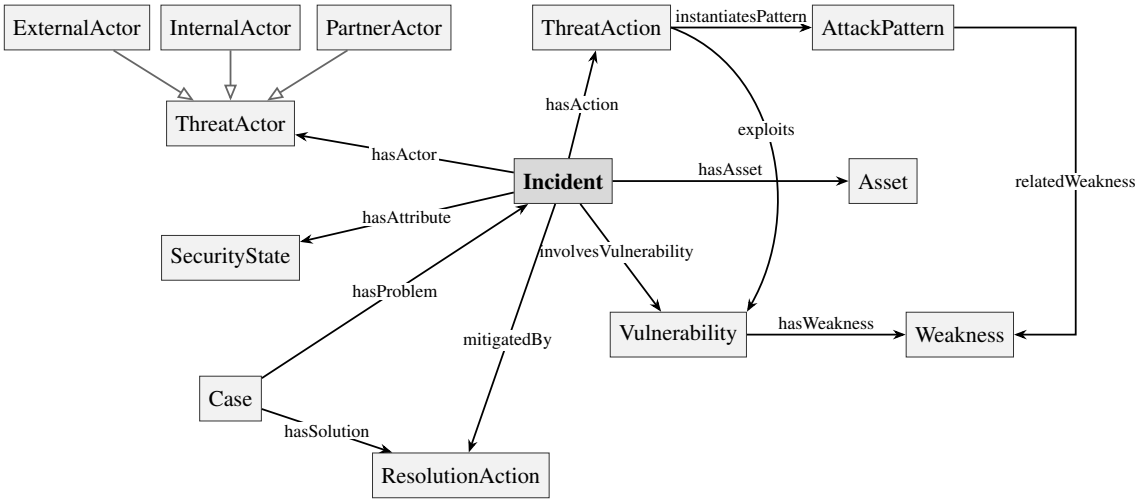


Figure 2. Núcleo da OntoCSIRT. Setas cheias são propriedades de objeto; setas com triângulo vazado são subclasses. As categorias de ativos e de fraquezas foram omitidas.

3.3. Formalização e implementação

A ontologia foi implementada em Turtle e tem 1323 triplas, 28 classes, 17 propriedades de objeto, 6 de dados, 7 de anotação e 139 indivíduos nomeados. Quatro axiomas `AllDisjointClasses` tornam disjuntas as onze classes de topo, as três categorias de ator, os quatro tipos de ativo e as seis categorias de fraqueza. A pontuação CVSS é uma propriedade funcional, de modo que duas pontuações para a mesma vulnerabilidade tornam a ontologia inconsistente. Todos os incidentes são declarados distintos com `owl:AllDifferent`, condição necessária para as regras que comparam incidentes.

Duas classes são definidas em OWL, sem regras: um incidente com risco à confidencialidade é um incidente cujo atributo afetado inclui a confidencialidade, e um incidente de risco crítico é aquele cujo nível de risco é *Critical*:

$$\mathit{ConfidentialityAtRisk} \equiv \mathit{Incident} \sqcap \exists\, \mathit{hasAttribute}.\{\mathit{State_Confidentiality}\}$$
$$\mathit{CriticalRiskIncident} \equiv \mathit{Incident} \sqcap \exists\, \mathit{hasRiskLevel}.\{\text{“Critical”}\}$$

As regras SWRL estão no próprio arquivo da ontologia, que é a sua única fonte (Tabela 2). As regras R1a a R1d derivam o nível de risco a partir do CVSS, por faixas; o valor derivado alimenta a classificação em *CriticalRiskIncident*, o que combina raciocínio por regras e por lógica de descrição. A R3 identifica ativos com dois ou mais incidentes críticos distintos. As regras R4 e R5 relacionam incidentes com o mesmo ator concreto e com a mesma CWE; as propriedades derivadas são simétricas. A R6 liga a camada de regras à de casos: propõe como candidata a solução de um caso cujo problema partilha a fraqueza do incidente. Todas as regras são *DL-safe* no sentido de se aplicarem a indivíduos nomeados [Motik et al., 2005].

Restrições de mundo fechado foram escritas em SHACL: todo incidente deve ter os quatro elementos VERIS e uma vulnerabilidade; toda vulnerabilidade deve ter exatamente uma pontuação CVSS decimal entre 0 e 10 e uma CWE; o nível de risco deve

Table 2. Regras SWRL da OntoCSIRT (forma abreviada; *dif* = `differentFrom`).

Regra	Corpo $\rightarrow$ Cabeça
R1a	$Incident(i) \land involvesVulnerability(i,v) \land cvssBaseScore(v,s) \land s \geq 9{,}0 \rightarrow hasRiskLevel(i,$"Critical"$)$
R1b–d	idem com as faixas [7,0; 9,0), [4,0; 7,0) e [0; 4,0) para *High*, *Medium* e *Low*
R3	$Asset(a) \land hasAsset(i_1,a) \land hasAsset(i_2,a) \land$ CVSS de i_1 e de $i_2 \geq 9{,}0 \land dif(i_1,i_2) \rightarrow RecurrentlyCriticalAsset(a)$
R4	$Incident(i_1) \land hasActor(i_1,x) \land hasActor(i_2,x) \land dif(i_1,i_2) \rightarrow sharesActorWith(i_1,i_2)$
R5	$involvesVulnerability(i_1,v_1) \land hasWeakness(v_1,w) \land involvesVulnerability(i_2,v_2) \land hasWeakness(v_2,w) \land dif(i_1,i_2) \rightarrow sharesWeaknessWith(i_1,i_2)$
R6	$sharesWeaknessWith(i,j) \land Case(c) \land hasProblem(c,j) \land hasSolution(c,s) \rightarrow candidateSolution(i,s)$

pertencer a um vocabulário controlado; identificadores CVE e CWE devem seguir os formatos oficiais; e todo caso deve ter um problema e uma solução.

3.4. Base de conhecimento

A base contém 24 incidentes históricos, cada um com o seu caso. Seis foram herdados da versão anterior e usam vulnerabilidades com CVE reais. Os outros dezoito são sintéticos e usam vulnerabilidades locais sem CVE, com pontuação atribuída localmente e assim marcada. Há cinco atores fictícios (três externos, um interno e um parceiro), sete ativos de quatro tipos, treze CWE, onze padrões de ataque e seis ações de resolução. As soluções dos casos seguem uma política de resposta definida antes da avaliação (Tabela 3); três casos registram exceções, isto é, decisões do analista que divergem da política (`Incident_01`, `Incident_03` e `Incident_24`).

Table 3. Política de resposta usada para registrar as soluções dos casos.

Situação	Ação registrada
Injeção no servidor com perda de confidencialidade	Isolar o ativo
Injeção no servidor com perda de integridade ou disponibilidade	Aplicar correção
Fraqueza do cliente web	Regra de firewall/WAF
Controle de acesso	Corrigir a autorização
Autenticação	Rotacionar credenciais
Tratamento inseguro de recursos	Aplicar correção
Falsificação de requisição no servidor	Segmentar a rede

3.5. Evolução e defeitos corrigidos

A Tabela 4 registra os principais defeitos da versão 6 e como foram corrigidos. A maior parte foi encontrada por revisão crítica do modelo e pelas verificações automáticas descritas na Seção 5..

Table 4. Defeitos da versão 6 corrigidos na versão 7.

Defeito na versão 6	Correção na versão 7
Padrões de ataque abstratos ligados a ativos concretos	Ação concreta (`ThreatAction`) separada do padrão
Ator genérico "atacante externo" tratado como indivíduo; regra de ator partilhado relacionava incidentes sem relação	Categorias VERIS como classes; atores concretos como indivíduos
Comentários "STIX SDO" em conceitos que não existem no STIX 2.1 (`TTP`, `Asset`) e relação `exploits` atribuída ao padrão de ataque	Alinhamento por anotação `stixType`, com correspondência aproximada declarada
Átomos SWRL com o tipo `swrl:ObjectPropertyAtom`, que não existe na sintaxe RDF da SWRL	Uso de `IndividualPropertyAtom` e `DatavaluedPropertyAtom` [Horrocks et al., 2004]
Risco derivado só para CVSS $\geq$ 9,0; regra de "ator prioritário" classificava todos os atores	Quatro faixas de risco; regra de ator prioritário removida
Regra de confidencialidade em SWRL	Classe definida em OWL
Atalhos redundantes (`leadsToCWE`, `cbrQueryCWE`) e indivíduos sem uso	Removidos; um único caminho incidente–vulnerabilidade–CWE
CVSS do CVE-2023-2065 registrado como 8,1	8,8 (pontuação secundária CVSS 3.1), marcado para verificação
Base de seis casos, um por tipo de ataque	24 casos e política de resposta explícita

4. Aplicação da Ontologia

4.1. Processamento

O processamento é feito por um único programa em Python. Como o Owlready2 [Lamy, 2017] não lê Turtle, a ontologia é convertida para RDF/XML com o rdflib e carregada no Owlready2, que invoca o Pellet [Sirin et al., 2007] com inferência de valores de propriedades de objeto e de dados. O Pellet aplica as regras SWRL e classifica os indivíduos nas classes definidas na mesma execução. O grafo resultante é exportado para o rdflib, onde são executadas as consultas SPARQL. A consistência da TBox é verificada também com o HermiT [Glimm et al., 2014], sem as regras, e as restrições com o pySHACL. O trecho abaixo mostra o núcleo da execução.

```
g = Graph(); g.parse("OntoCSIRT_v7.ttl", format="turtle")
g.serialize("onto.owl", format="xml")        # Owlready2 nao le Turtle
world = owlready2.World()
onto = world.get_ontology("file://onto.owl").load(format="rdfxml")
owlready2.sync_reasoner_pellet(world, infer_property_values=True,
                               infer_data_property_values=True)
```

4.2. Cenário: um incidente novo

O cenário é o da versão anterior, para permitir comparação: um alerta registra um incidente de referência direta insegura a objeto (IDOR) na base de dados 1, realizado pelo ator externo FIN-A e com perda de confidencialidade, envolvendo a vulnerabilidade CVE-2023-2065 (CWE-639). O incidente é inserido como `Incident_New`, com a sua

ação concreta, e declarado diferente de todos os incidentes históricos.

O raciocínio derivou: nível de risco *High*, pela regra R1b, já que o CVSS é 8,8; a classe *ConfidentialityAtRisk*, pela definição OWL; 3 incidentes com a mesma fraqueza (R5); 7 incidentes com o mesmo ator concreto (R4); e três soluções candidatas pela R6: corrigir a autorização, isolar o ativo e regra de WAF. O tempo de raciocínio do Pellet nesta execução, incluindo o arranque da máquina virtual Java, foi de 3,35 s.

4.3. Recuperação de casos ranqueada

A R6 propõe candidatas, mas não as ordena. Para ordenar os casos, foi definida uma função de similaridade sobre as características que a ontologia fornece para cada incidente, com pesos fixados antes da avaliação:

$$S(q,c) = 0{,}35\,s_W + 0{,}15\,s_P + 0{,}20\,s_A + 0{,}20\,s_T + 0{,}10\,s_X \tag{1}$$

onde:

$s_W = 1$ se a CWE é a mesma, 0,5 se a categoria de fraqueza é a mesma, e 0 caso contrário;

$s_P = 1$ se o padrão de ataque é o mesmo, e 0 caso contrário;

$s_A = 1$ se o ativo é o mesmo, 0,7 se o tipo de ativo é o mesmo, e 0 caso contrário;

$s_T = 1$ se o atributo afetado é o mesmo, e 0 caso contrário;

$s_X = 1$ se o ator é o mesmo, 0,5 se a categoria VERIS é a mesma, e 0 caso contrário.

As categorias de fraqueza, de ativo e de ator vêm das classes da ontologia, obtidas por consulta SPARQL depois do raciocínio. A solução do caso não entra na similaridade. A Tabela 5 mostra os cinco casos mais semelhantes ao incidente novo.

Table 5. Cinco casos mais semelhantes ao incidente novo (gerada a partir da evidência).

Incidente	$S(q,c)$	Solução registrada
Incident_03	1,00	WAFRule
Incident_17	0,84	AccessControlFix
Incident_24	0,80	Isolate
Incident_09	0,57	AccessControlFix
Incident_07	0,39	Isolate

O primeiro colocado, `Incident_03`, tem o mesmo problema do incidente novo, mas a sua solução registrada é uma das três exceções à política. As posições 2 e 4 trazem a solução prevista pela política, corrigir a autorização. Para comparação, a junção usada na versão anterior (mesma categoria de ator ou mesma CWE) devolve 20 dos 24 incidentes, sem ordem, e a solução mais frequente entre eles é aplicar correção, que não se aplica a uma falha de autorização.

5. Avaliação e Resultados

Todos os resultados referem-se ao arquivo da ontologia cujo SHA-256 começa por `8c2fc5f00fae`, processado com Python 3.13.18, rdflib 7.6.0 e Owlready2 0.25 (que

inclui o Pellet 2.3.1 e o HermiT). Cada resultado é gravado em arquivos de evidência gerados pelo mesmo programa, que também gera os números citados neste texto.

5.1. Consistência e restrições

O HermiT considerou a TBox consistente, com 0 classes insatisfazíveis, em 1,36 s. O Pellet considerou a ontologia completa, com indivíduos e regras, consistente, em 3,35 s. A validação SHACL foi conforme, com 0 violações. Esses resultados mostram que existe um modelo da ontologia e que os dados satisfazem as restrições declaradas; não mostram que a modelagem é correta para o domínio.

5.2. Questões de competência e testes de regras

As 8 questões de competência da Tabela 1 foram executadas sobre o grafo inferido e comparadas com as respostas esperadas: 8 de 8 coincidiram. As questões CQ1 a CQ5 e a CQ7 dependem de inferências (regras e classes definidas) e, por isso, também testam o raciocínio.

Cada regra foi testada em dados mínimos, com casos que devem e que não devem disparar. Para a R1, testaram-se as fronteiras das faixas (10,0; 9,0; 8,9; 7,0; 6,9; 4,0; 3,9; 0,1). Para as demais, testaram-se, por exemplo, dois incidentes críticos no mesmo ativo contra um crítico e um médio, o mesmo ator contra atores diferentes da mesma categoria, a simetria das propriedades derivadas e a ausência de autorrelação. Passaram 20 de 20 testes. Durante o desenvolvimento, esses testes falharam e revelaram dois problemas, discutidos na Seção 5.5..

5.3. Injeção de defeitos

Para verificar se as verificações detectam erros, foram criadas 10 versões da base, cada uma com um defeito: um indivíduo em duas classes disjuntas (três variantes), duas pontuações CVSS para a mesma vulnerabilidade, CVSS como texto, incidente sem ator, caso sem solução, nível de risco fora do vocabulário, CVSS acima de 10 e CVE mal formado. Os 10 defeitos foram detectados: 4 pelo Pellet, como inconsistência, e 7 pelo SHACL. O CVSS como texto foi detectado pelos dois. A segunda pontuação CVSS foi detectada apenas pelo SHACL: embora a propriedade seja funcional, o Pellet, na configuração usada, não acusou inconsistência, e a causa não foi investigada. Isso mostra que OWL e SHACL são complementares e que nenhuma das duas verificações deve ser usada sozinha.

5.4. Avaliação da recuperação

A recuperação foi avaliada por validação cruzada *leave-one-out*: cada um dos 24 incidentes foi usado como consulta contra os outros 23, e um caso foi considerado relevante quando a sua solução registrada é igual à da consulta. Como a solução não entra em nenhuma estratégia, a relevância é independente da similaridade. Foram medidas a acurácia do primeiro colocado (Acc@1) e a precisão nos três primeiros (P@3); quando há empates, os valores são as esperanças com desempate aleatório. A Tabela 6 compara

seis estratégias.

Table 6. Avaliação *leave-one-out* da recuperação (24 consultas).

Estratégia	Acc@1	P@3	Cobertura
Classe majoritária (sempre a solução mais frequente)	0,29	0,29	1,00
Junção da versão 6: mesma categoria de ator ou mesma CWE, sem ordem	0,25	0,24	1,00
Mesmo ator concreto (R4), sem ordem	0,24	0,23	1,00
Mesma CWE (R5 e R6), sem ordem	0,50	0,22	0,79
Similaridade da Equação (1) com pesos iguais	0,62	0,45	1,00
Similaridade da Equação (1) com os pesos definidos	0,69	0,49	1,00

A junção da versão 6 e o critério de ator ficaram abaixo da classe majoritária: o ator não informa a resposta. As regras R5 e R6 acertam metade das vezes, mas não cobrem as consultas cuja CWE não se repete na base (cobertura de 0,79). A similaridade baseada na ontologia teve o melhor resultado, inclusive com pesos iguais, o que indica que o ganho vem da representação, e não do ajuste dos pesos.

A ablação, que retira um componente de cada vez, levou a Acc@1 a 0,49 sem a fraqueza, 0,52 sem o padrão de ataque, 0,68 sem o ativo, 0,67 sem o atributo e 0,68 sem o ator. A fraqueza e o padrão de ataque carregam a maior parte da informação; o ator praticamente nenhuma.

Dos erros do primeiro colocado (com desempate pela ordem dos identificadores), cinco envolvem as três exceções, como consulta ou como caso recuperado, e dois são injeções com perda de integridade ou disponibilidade que recuperaram injeções com perda de confidencialidade. Como as três exceções não são previsíveis a partir do problema, a acurácia máxima atingível nesta base é de 21/24, isto é, 0,875.

5.5. Achados sobre as ferramentas

O protocolo encontrou três problemas fora da ontologia. Primeiro, numa versão da R3 que usava a classe definida *CriticalRiskIncident* no corpo, o Pellet deixou de emitir, em parte dos dados de teste, os valores de risco produzidos pela R1; a R3 foi reescrita para ler o CVSS diretamente, e o problema não voltou a ocorrer. Segundo, na versão do Owlready2 usada, a leitura dos valores de dados devolvidos pelo Pellet divide literais que contêm vírgulas, o que corrompeu um literal; os valores de dados passaram a ser escritos sem vírgulas, e a exportação passou a descartar e contar linhas inválidas. Terceiro, um defeito no próprio programa de testes fazia todos os testes positivos falharem; foi identificado porque os testes negativos passavam e os positivos não. Os três casos reforçam o valor de testes com resultados esperados que podem falhar.

5.6. Limitações

A base de casos é pequena e, em 18 dos 24 casos, sintética; a política de resposta foi definida pelo autor e, por isso, a avaliação mostra se a recuperação reconstrói uma política conhecida, e não se as respostas são eficazes. Três dos seis CVE reais ainda não

foram verificados contra o NVD nesta versão (CQ8). Não houve avaliação por especialistas. Os tempos de raciocínio foram medidos numa única execução. O alinhamento com o STIX e com o D3FEND é por anotação e não foi curado com especialistas.

6. Comparação com Trabalhos Relacionados

A Tabela 7 compara este trabalho com os mais próximos, nos atributos relatados nas respectivas publicações ("n/r": não relatado).

Table 7. Comparação com os trabalhos mais próximos.

	OntoCSD [Wu et al., 2024]	Guerra et al. [Guerra et al., 2023]	CIRPO [Galadima et al., 2027]	OntoCSIRT v7
Foco	Defesa de redes e decisão	Reúso de soluções de incidentes	Processo e comunicações da resposta	Análise do incidente e recuperação de casos
Ontologia	5 classes principais, 11 relações	Ontologia de ações de resolução	Estende a CSIHO	28 classes, VERIS A4, CVE/CWE
Regras	4 SWRL (HermiT)	Não usa para descoberta	n/r	8 SWRL e 2 classes definidas (Pellet)
Casos	11 casos (myCBR, 26 atributos)	102 casos revisados	Exercício simulado	24 casos, 18 sintéticos
Avaliação	12 especialistas ($W = 0{,}695$) e 4 cenários	4 especialistas e *leave-one-out*	Estudo de caso	CQs, testes de regras, mutações e *leave-one-out* com 5 bases

Em relação ao OntoCSD, a OntoCSIRT mantém a ideia de usar regras antes dos casos, mas modela o incidente segundo o VERIS, separa padrões abstratos de ações concretas, liga regras e casos pela R6 e verifica cada regra com testes. O OntoCSD tem o que falta aqui: validação por especialistas e cenários num sistema real. Em relação a Guerra et al., a OntoCSIRT acrescenta regras de descoberta e uma similaridade que usa a hierarquia da ontologia, mas a sua base é menor e sintética, e as suas soluções são ações únicas, e não planos ordenados. Em relação à CIRPO, o foco é complementar: a CIRPO descreve o processo de resposta, e a OntoCSIRT, o conteúdo técnico do incidente e a escolha da resposta.

7. Conclusão e Trabalhos Futuros

Este trabalho desenvolveu a OntoCSIRT, uma ontologia OWL 2 DL com oito regras SWRL e duas classes definidas para análise de incidentes de cibersegurança, e aplicou-a à recuperação de casos de resposta. A ontologia foi processada com Owlready2, Pellet, HermiT, SPARQL e SHACL. O protocolo de avaliação confirmou as questões de competência, as regras e a detecção de defeitos, e mostrou que a recuperação baseada nas classes da ontologia supera tanto a junção da versão anterior quanto a classe majoritária. O cenário mostrou também um limite do CBR: um caso idêntico ao problema pode trazer

uma solução excepcional, o que torna necessárias as etapas de revisão e retenção.

Como trabalhos futuros, propõe-se: (i) validar a ontologia e as recomendações com especialistas de CSIRT, calculando a concordância como no OntoCSD; (ii) substituir os casos sintéticos por casos reais anonimizados e verificar automaticamente todos os CVE contra o NVD; (iii) alinhar as ações de resolução ao D3FEND e os padrões de ataque ao CAPEC e ao ATT&CK, com curadoria; (iv) implementar as etapas de revisão e retenção do ciclo CBR, sinalizando casos que divergem da política; (v) avaliar a ontologia com o OOPS! [Poveda-Villalón et al., 2014] e publicá-la segundo os princípios FAIR [Oliveira et al., 2021]; e (vi) usar a ontologia e as restrições SHACL para verificar ações propostas por modelos de linguagem [Hammar et al., 2026, Cotti et al., 2026].

Disponibilidade. A ontologia, as restrições SHACL, o programa de processamento e os arquivos de evidência acompanham este artigo. Dados de vulnerabilidades usam a API do NVD, mas este trabalho não é endossado nem certificado pelo NVD.

Referências

[Aamodt and Plaza, 1994] Aamodt, A. and Plaza, E. (1994). Case-based reasoning: Foundational issues, methodological variations, and system approaches. *AI Communications*, 7(1):39–59.

[Cotti et al., 2026] Cotti, L., Drago, I., Rula, A., Bianchini, D., and Cerutti, F. (2026). OntoLogX: Ontology-guided knowledge graph extraction from cybersecurity logs with large language models. *Advanced Intelligent Systems*. Preprint arXiv:2510.01409.

[Fernández-López et al., 1997] Fernández-López, M., Gómez-Pérez, A., and Juristo, N. (1997). METHONTOLOGY: From ontological art towards ontological engineering. In *Proceedings of the AAAI97 Spring Symposium on Ontological Engineering*, pages 33–40.

[Galadima et al., 2027] Galadima, H. S., Doherty, C., and Brennan, R. (2027). Graph analysis of incident response process activities and communications. In *Availability, Reliability and Security: ARES 2026 International Workshops (LNCS 16901)*, pages 407–425. Springer. Publicado online em 18 ago. 2026.

[Glimm et al., 2014] Glimm, B., Horrocks, I., Motik, B., Stoilos, G., and Wang, Z. (2014). HermiT: An OWL 2 reasoner. *Journal of Automated Reasoning*, 53(3):245–269.

[Grüninger and Fox, 1995] Grüninger, M. and Fox, M. S. (1995). Methodology for the design and evaluation of ontologies. In *IJCAI Workshop on Basic Ontological Issues in Knowledge Sharing*.

[Guerra et al., 2023] Guerra, P. A. C., Barcelos, F. A., Nunes, R. C., de Freitas, E. P., and Silva, L. A. d. L. (2023). An artificial intelligence framework for the representation and reuse of cybersecurity incident resolution knowledge. In *12th Latin-American Symposium on Dependable and Secure Computing (LADC)*, pages 136–145. ACM.

[Hammar et al., 2026] Hammar, K., Alpcan, T., and Lupu, E. C. (2026). Incident response planning using a lightweight large language model with reduced hallucination. In *Network and Distributed System Security Symposium (NDSS)*. arXiv:2508.05188.

[Horrocks et al., 2004] Horrocks, I., Patel-Schneider, P. F., Boley, H., Tabet, S., Grosof, B., and Dean, M. (2004). SWRL: A semantic web rule language combining OWL and RuleML. Member submission, W3C.

[Kaloroumakis and Smith, 2021] Kaloroumakis, P. E. and Smith, M. J. (2021). Toward a knowledge graph of cybersecurity countermeasures. Technical report, The MITRE Corporation.

[Kanawati et al., 2026] Kanawati, R., Lammari, N., and Mimouni, N. (2026). A contextualized cybersecurity incident remediation ontology. In *12th International Conference on Information Systems Security and Privacy (ICISSP)*, pages 358–365. Dados conforme listados em Galadima et al. (2026).

[Kiesling et al., 2019] Kiesling, E., Ekelhart, A., Kurniawan, K., and Ekaputra, F. (2019). The SEPSES knowledge graph: An integrated resource for cybersecurity. In *The Semantic Web – ISWC 2019*, pages 198–214. Springer.

[Knublauch and Kontokostas, 2017] Knublauch, H. and Kontokostas, D. (2017). Shapes constraint language (SHACL). W3C Recommendation.

[Lamy, 2017] Lamy, J.-B. (2017). Owlready: Ontology-oriented programming in Python with automatic classification and high level constructs for biomedical ontologies. *Artificial Intelligence in Medicine*, 80:11–28.

[MITRE, 2026] MITRE (2026). Common weakness enumeration (CWE). Disponivel em `https://cwe.mitre.org`.

[Moreira, 2018] Moreira, G. B. (2018). CSIHO: an ontology for computer security incident handling. In *Simpósio Brasileiro de Segurança da Informação e de Sistemas Computacionais (SBSeg)*, pages 1–14. Dados conforme listados em Galadima et al. (2026).

[Motik et al., 2005] Motik, B., Sattler, U., and Studer, R. (2005). Query answering for OWL-DL with rules. *Journal of Web Semantics*, 3(1):41–60.

[Nelson et al., 2025] Nelson, A., Rekhi, S., Scarfone, K., and Souppaya, M. (2025). Incident response recommendations and considerations for cybersecurity risk management: A CSF 2.0 community profile. NIST Special Publication 800-61r3, National Institute of Standards and Technology.

[NIST, 2026] NIST (2026). National vulnerability database (NVD) – API 2.0. Disponivel em `https://nvd.nist.gov`. Este produto usa dados da API do NVD, mas nao e endossado nem certificado pelo NVD.

[OASIS, 2021] OASIS (2021). STIX version 2.1. OASIS Standard. Disponivel em `https://docs.oasis-open.org/cti/stix/v2.1/os/stix-v2.1-os.html`.

[Oliveira et al., 2021] Oliveira, Í., Fumagalli, M., Prince Sales, T., and Guizzardi, G. (2021). How FAIR are security core ontologies? a systematic mapping study. In *Research Challenges in Information Science (RCIS 2021)*, pages 107–123. Springer.

[Poveda-Villalón et al., 2014] Poveda-Villalón, M., Gómez-Pérez, A., and Suárez-Figueroa, M. C. (2014). OOPS! (OntOlogy pitfall scanner!): An on-line tool for ontology evaluation. *International Journal on Semantic Web and Information Systems*, 10(2):7–34.

[Sirin et al., 2007] Sirin, E., Parsia, B., Grau, B. C., Kalyanpur, A., and Katz, Y. (2007). Pellet: A practical OWL-DL reasoner. *Journal of Web Semantics*, 5(2):51–53.

[Syed et al., 2016] Syed, Z., Padia, A., Finin, T., Mathews, L., and Joshi, A. (2016). UCO: a unified cybersecurity ontology. In *AAAI Workshop on Artificial Intelligence for Cyber Security*, pages 195–202. Dados conforme listados em Galadima et al. (2026).

[Tailhardat et al., 2024] Tailhardat, L., Chabot, Y., and Troncy, R. (2024). NORIA-O: an ontology for anomaly detection and incident management in ICT systems. In *The Semantic Web – ESWC 2024*. Springer. Dados conforme listados em Galadima et al. (2026).

[VERIS Community, 2026] VERIS Community (2026). VERIS: The vocabulary for event recording and incident sharing – A4 threat model. Disponivel em `https://verisframework.org/incident-desc.html`. Acesso em: 2 nov. 2026.

[W3C OWL Working Group, 2012] W3C OWL Working Group (2012). OWL 2 web ontology language document overview (second edition). W3C Recommendation.

[W3C SPARQL Working Group, 2013] W3C SPARQL Working Group (2013). SPARQL 1.1 overview. W3C Recommendation.

[Wu et al., 2024] Wu, D., Chen, J., Xie, R., and Chen, K. (2024). OntoCSD: an ontology-based security model for an integrated solution of cyberspace defense. *Frontiers of Information Technology & Electronic Engineering*, 25(9):1209–1225.